

Shopify Expiring Token Management

How expiring Shopify Admin tokens are minted, refreshed, and recovered — the client-credentials and refresh-token grants, and the dead-refresh-token failure mode to design around.

Requirement

As of **April 2026**, Shopify mandates that all OAuth apps use **expiring offline access tokens with rotation**. Non-expiring tokens return `403: Non-expiring access tokens are no longer accepted for the Admin API`. This affects every Shopify Admin API call made by CRM Sync — customer sync, product queries, order lookups, webhook registration, and storefront token provisioning.

What Changed

BEFORE (PRE-APRIL 2026)	AFTER (MANDATORY)
Access token never expires	Access token expires ~24 hours after issuance
No refresh token issued	Refresh token issued alongside access token
Store once, use forever	Must refresh before expiry; refresh token rotates on each use
Token prefix: <code>shpat_</code>	Token prefix: <code>shpua_</code> (OAuth expiring)

Compliance Flag

The Shopify app must declare expiring token support:

```
// app/shopify.server.ts

shopifyApp({

  // ...

  future: {

    expiringOfflineAccessTokens: true,

  },

});
```

The OAuth token exchange must include `expiring: "1"`:

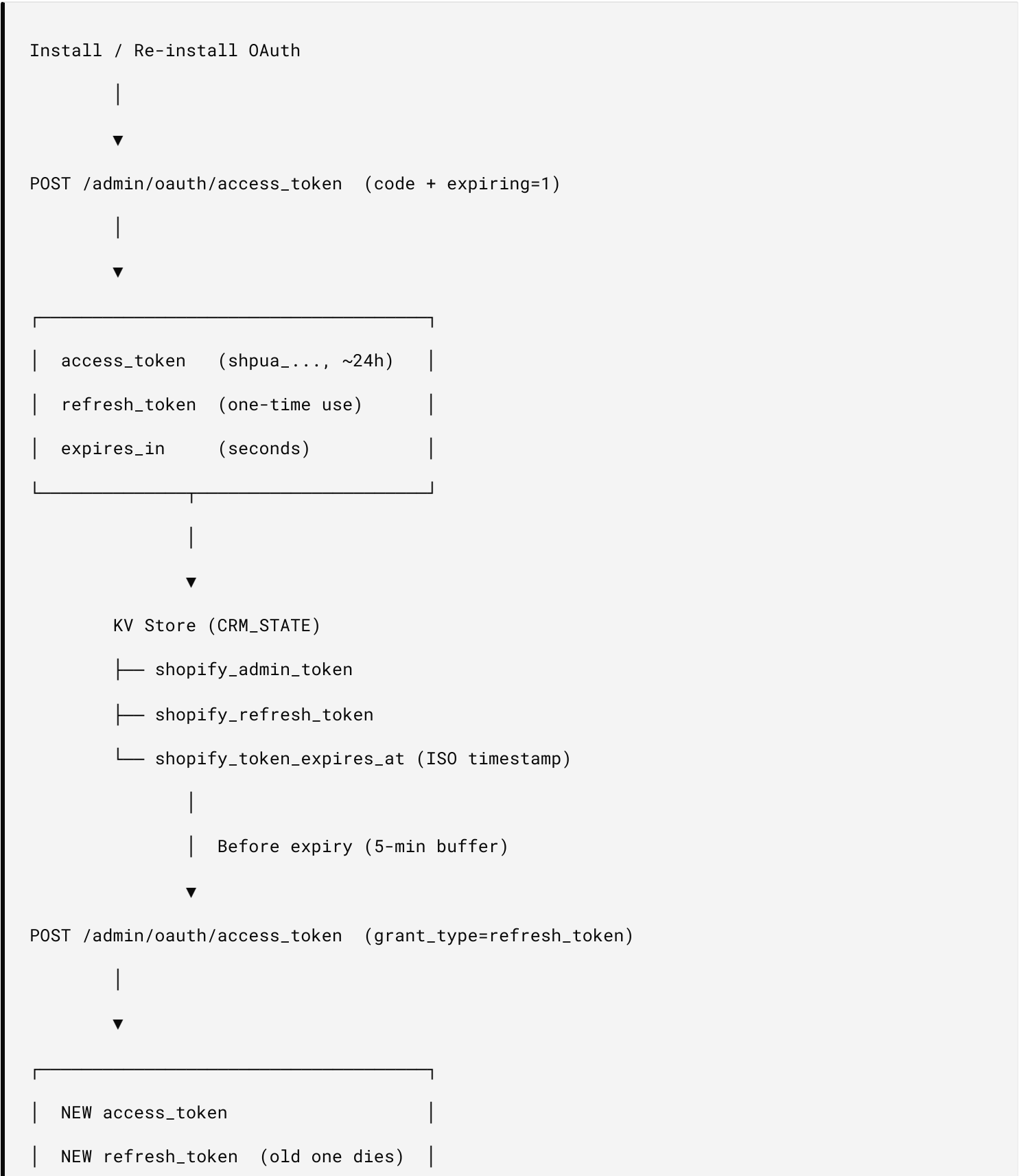
```
POST https://{shop}/admin/oauth/access_token

Content-Type: application/x-www-form-urlencoded

client_id={id}&client_secret={secret}&code={code}&expiring=1
```

Architecture

Token Lifecycle



```
| NEW expires_in |  
|  
|
```

Three Token Surfaces

SURFACE	WHAT IT DOES	WHEN
Shopify App loader (<code>app/routes/app.tsx</code>)	Sends <code>session.accessToken</code> to CRM worker via <code>POST /config?shop=</code>	Every time merchant opens the app
CRM Worker cron (<code>*/15 * * * *</code>)	Calls <code>refreshShopifyTokenIfNeeded()</code> with 5- min buffer before expiry	Every 15 minutes
Settings page (<code>/admin/shopify-refresh</code>)	Force-refresh via manual button click	On demand

Multi-Tenant Token Storage

Each tenant's tokens are stored independently in KV under `tenant:{shop}:`

```
{  
  "shopify_admin_token": "shpua_...",  
  "shopify_refresh_token": "shprf_...",  
  "shopify_token_expires_at": "2026-05-21T19:00:00.000Z",  
  "shopify_store_domain": "hx-stage.myshopify.com",  
  "shopify_app_secret": "..."  
}
```

The cron iterates all registered tenants and refreshes each independently.

Implementation Reference

Core Refresh Function

`workers/crm-sync/src/index.ts` — `refreshShopifyTokenIfNeeded()`

- Reads tenant config from KV
- Skips if no `refresh_token` or `token_expires_at` stored
- Skips if more than 5 minutes remain before expiry (unless `force=true`)
- Calls `POST https://{shop}/admin/oauth/access_token` with `grant_type=refresh_token`
- Saves new `access_token`, `refresh_token`, and computed `expires_at` back to KV
- Updates in-memory `cfg.shopifyAdminToken` for the current request

Where Refresh Is Called

CALL SITE	TRIGGER
<code>shopifyAdminGql()</code>	Before every Admin API GraphQL call
<code>createShopifyCustomerIfMissing()</code>	Before customer creation
<code>scheduled()</code> cron handler	Per-tenant before customer sync
<code>POST /admin/shopify-refresh</code>	Manual force-refresh from Settings UI

OAuth Install Flow

`/admin/shopify-install` → redirect to Shopify OAuth → `/admin/shopify-callback`

The callback handler:

1. Exchanges authorization `code` for tokens with `expiring: "1"`
2. Stores `access_token`, `refresh_token`, `expires_at` in tenant KV
3. Registers the tenant via `registerTenant()`

4. Auto-registers `CUSTOMERS_CREATE` and `CUSTOMERS_UPDATE` webhooks

Shopify App Session Sync

`app/routes/app.tsx` loader:

- 1. Authenticates the admin session via `shopify.authenticate.admin()`
- 2. Sends `session.accessToken` to CRM worker via `POST /config?shop=`
- 3. Provisions a Storefront API token via Admin API if not already present
- 4. The CRM worker maps `shopify_access_token` → `shopify_admin_token`

This ensures the CRM worker always has a fresh token when the merchant opens the app, even if the cron-refreshed token has expired.

Required Scopes

Declared in `shopify.app.crm-sync.toml` under `[access_scopes]`:

SCOPE	PURPOSE
<code>read_customers</code>	Customer sync, identity lookup
<code>write_customers</code>	Customer creation, tag/metafield writes
<code>customer_read_customers</code>	Customer Account API reads
<code>customer_write_customers</code>	Customer Account API writes
<code>read_products</code>	Shop embed product grid
<code>read_orders</code>	Order history in dashboard

Scopes in the TOML must match the OAuth install URL request. Shopify silently drops undeclared scopes. Deploy scope changes with:

```
npx shopify app deploy --config=shopify.app.crm-sync.toml
```

Diagnostics

Settings Page Indicators

The `/settings` admin page shows:

- **Token Type:** `OAuth (expiring)` for `shpua_` prefix, `Admin API` for `shpat_` (legacy)
- **Refresh Token:** `Present` Or `None`
- **Expires:** ISO timestamp with countdown
- **API Health: Tests** `GET /admin/api/2026-04/shop.json` with current token

Manual Actions

BUTTON	ENDPOINT	WHAT IT DOES
Force Refresh	<code>POST /admin/shopify-refresh</code>	Refreshes immediately regardless of expiry
Test API	<code>GET /admin/shopify-test</code>	Calls Shop API and returns status
Re-install OAuth	<code>GET /admin/shopify-install?shop=</code>	Starts fresh OAuth flow

Common Failures

SYMPTOM	CAUSE	FIX
<code>403: Non-expiring access tokens</code>	Using legacy <code>shpat_</code> token	Re-install OAuth to get <code>shpua_</code> token
<code>401: [API] Invalid API key</code>	Token expired and refresh failed	Check <code>shopify_app_secret</code> in KV, force refresh
Refresh returns 400	Refresh token already used (rotated)	Re-install OAuth
<code>shopify_refresh_token: None</code>	Initial install didn't include <code>expiring: "1"</code>	Re-install OAuth
Cron not refreshing	No tenants registered	Call <code>POST /config?shop=</code> to register

Operational Checklist

- ☐ `shopify.server.ts` has `expiringOfflineAccessTokens: true`
- ☐ OAuth token exchange includes `expiring: "1"` parameter
- ☐ `shopify_app_secret` is stored in tenant KV config
- ☐ Cron trigger `*/15 * * * *` is active in `wrangler.toml`
- ☐ Settings page shows token type `OAuth (expiring)` with refresh token present
- ☐ `shopify.app.crm-sync.toml` declares all required scopes
- ☐ App deployed after scope changes: `npx shopify app deploy --config=shopify.app.crm-sync.toml`